

Security Audit

Zilliqa (L1 Blockchain)

Table of Contents

Executive Summary	4
Project Context	4
Audit scope	7
Security Rating	8
Intended Smart Contract Functions	9
Code Quality	10
Audit Resources	10
Dependencies	10
Severity Definitions	11
Status Definitions	12
Audit Findings	13
Centralisation	17
Conclusion	18
Our Methodology	19
Disclaimers	21
About Hashlock	22

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The Zilliqa team partnered with Hashlock to conduct a security audit of their deposit_v4.sol smart contract. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

Zilliqa is a layer-1 blockchain platform founded in Singapore in 2017 that pioneered sharding technology to enhance blockchain scalability and performance. Designed to be secure, scalable, and easy to use, the blockchain serves as a versatile foundation that facilitates a broad array of Web3 applications and provides a robust platform for emerging developers and established enterprises alike.

Zilliqa's native token, ZIL, facilitates transactions and interactions within its ecosystem. The blockchain supports EVM languages such as Solidity, as well as its own secure-by-design smart contract language, Scilla.

The next evolution of the network, Zilliqa 2.0, is currently under development and offers an efficient, scalable, and customisable platform designed to drive the mass adoption of Web3 through x-shards, native account abstraction, fast finality, and more.

Project Name: Zilliqa

Project Type: L1 Blockchain

Compiler Version: ^0.8.20

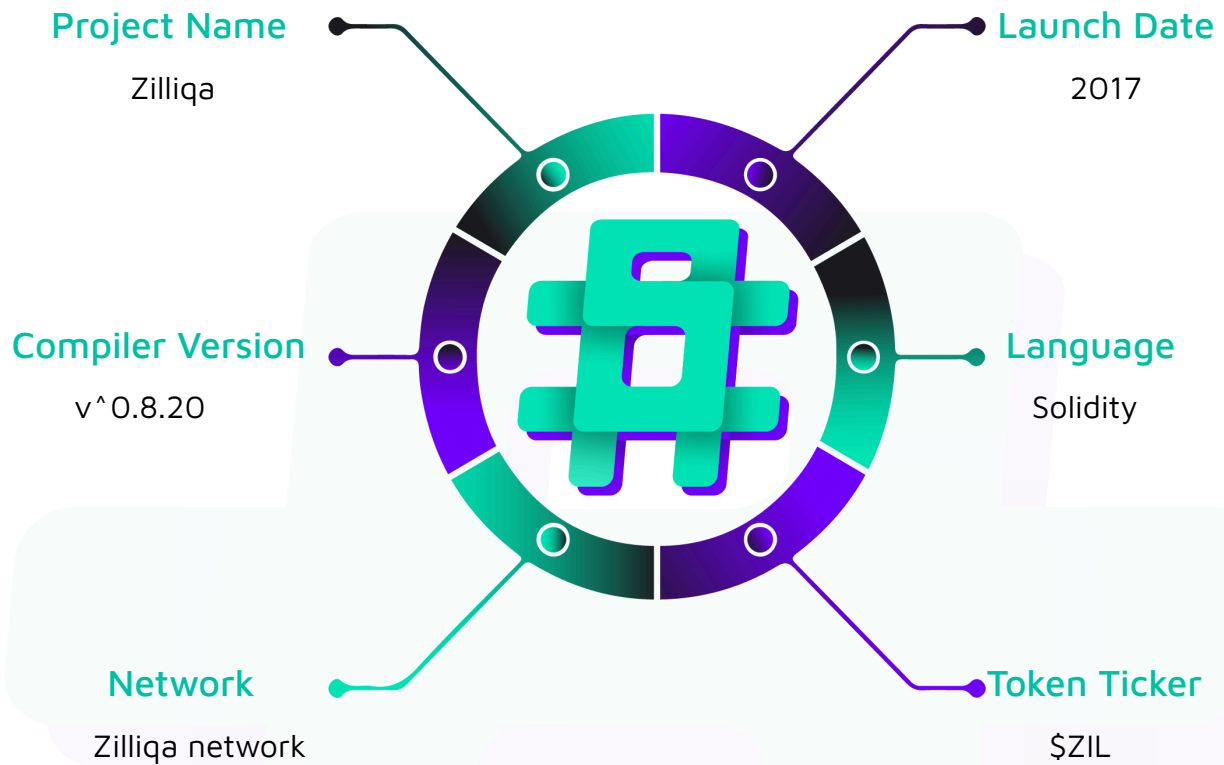
Website: www.zilliqa.com

Logo:

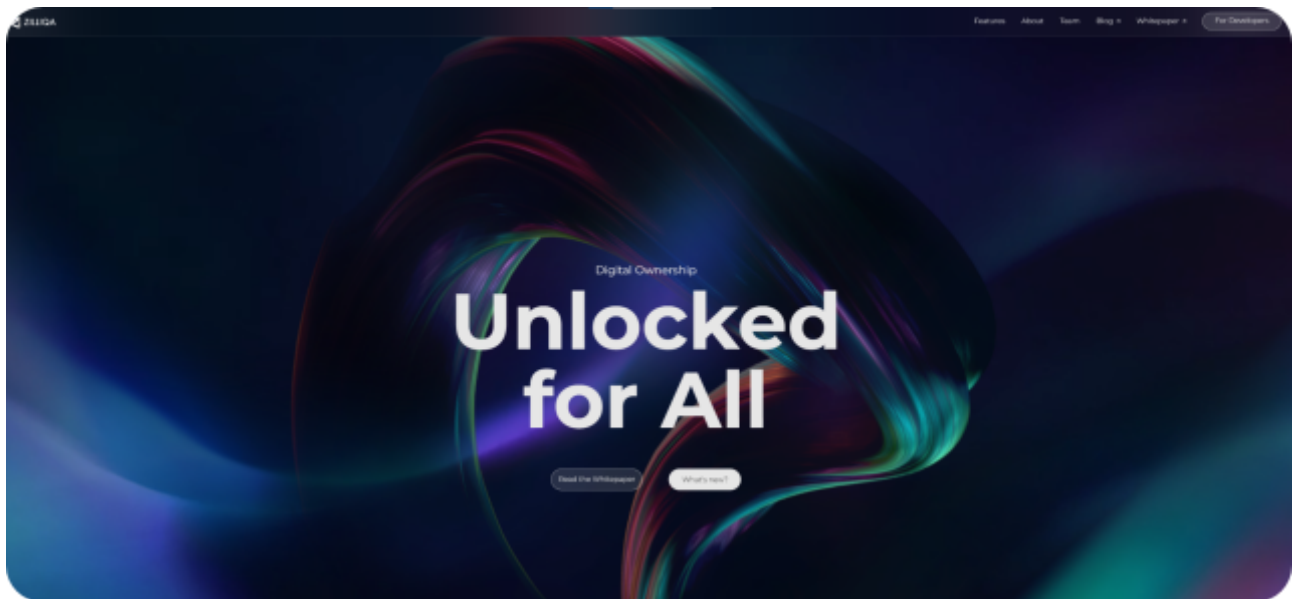


#hashlock.

Hashlock Pty Ltd

Visualised Context:

Project Visuals:



Welcome to the future of Zilliqa.

Experience the power of the user-first blockchain, built by the pioneers of sharding.

[Read more about Zilliqa](#)

The core features of Zilliqa 2.0



X-SHARDS

Scale and customise the blockchain to your needs.



CONSENSUS

Making the blockchain fast and energy efficient.



SMART ACCOUNTS

Making the blockchain easy to use for everyone.



Audit scope

We at Hashlock audited the solidity code within the Zilliqa project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	Zilliqa Smart Contracts
Platform	Zilliqa / Solidity
Audit Date	January, 2025
Contract 1	deposit_v4.sol
Contract 1 MD5 Hash	ae505fe5076afe4fa73effdf13460a2d
GitHub Commit Hash	cdc702f1d482453055f554846915c659e55d397b

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Open Zeppelin contracts. We initially identified some vulnerabilities that have since been addressed.



Not Secure

Vulnerable

Secure

Hashlocked

The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The general security overview is presented in the [Standardised Checks](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been resolved and acknowledged.

Hashlock found:

- 1 Low severity vulnerabilities
- 1 Gas Optimisation
- 2 QAs

Caution: Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
deposit_v4.sol - Allows users to: - Deposit/Unstake/Withdraw funds	Contract achieves this functionality.

Code Quality

This audit scope involves the smart contracts of the Zilliqa project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring was recommended.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Zilliqa project smart contract code in the form of Github access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Low

[L-01] depositv4 - Indices array not initialized in getStakersData

Description

The `getStakersData` function declares but does not initialize the indices array, which could lead to unexpected reverts when the function is called.

Vulnerability Details

The function declares indices as part of its return values but never initializes it with new `uint256`, unlike the balances and stakers arrays which are properly initialized. Due to this, function calls to `getStakersData` will revert due to accessing an uninitialized array. However, the function is view-only which limits the impact.

```
function getStakersData()

    public

    view

    returns (

        bytes[] memory stakerKeys,

        uint256[] memory indices,

        uint256[] memory balances,

        Staker[] memory stakers

    )

{

    // TODO clean up double call to _getDepositStorage() here

    DepositStorage storage $ = _getDepositStorage();
```

```

Committee storage currentCommittee = committee();

stakerKeys = currentCommittee.stakerKeys;

balances = new uint256[](stakerKeys.length);

stakers = new Staker[](stakerKeys.length);

for (uint256 i = 0; i < stakerKeys.length; i++) {

    bytes memory key = stakerKeys[i];

    // The stakerKeys are not sorted by the stakers'
    // index in the current committee, therefore we
    // return the indices too, to help identify the
    // stakers in the bit vectors stored along with
    // BLS aggregate signatures

    indices[i] = currentCommittee.stakers[key].index;

    balances[i] = currentCommittee.stakers[key].balance;

    stakers[i] = $_stakersMap[key];

}

}

```

Impact

Function calls to `getStakersData` will revert due to accessing an uninitialized array.

Recommendation

Initialize the indices array with `indices = new uint256[](stakerKeys.length)` before the loop.

Status

Resolved

Gas

[G-01] deposit_v4#unstake - `futureCommittee.stakers[blsPubKey].balance` could be cached to save gas

Description

The `unstake` function reads the `futureCommittee.stakers[blsPubKey].balance` value from storage multiple times.

Recommendation

Cache the `futureCommittee.stakers[blsPubKey].balance` value and use it in the function instead of reading the value from storage multiple times.

Status

Resolved

QA

[Q-01] deposit_v4#leaderFromRandomness, getStakersData - `TODO` comments still exist

Description

The `leaderFromRandomness` and `getStakersData` functions still have `TODO` comments.

Having such comments on production could reduce the code quality.

Recommendation

Remove the `TODO` comments.

Status

Resolved

[Q-02] deposit_v4 - Floating pragma

Description

The contracts use `pragma solidity ^0.8.20`.

This can allow the contracts to be deployed with the wrong pragma version which is different from the one the contracts were tested with.

Recommendation

Lock the pragma version.

Status

Resolved

Centralisation

The Zilliqa project values community-centered and transparency over centralisation.

Zilliqa emphasizes a community-centric approach while maintaining transparency. The project strives to balance decentralization with internal team accountability. This blend ensures operational security while keeping the protocol aligned with decentralized values.



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the Zilliqa project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved and acknowledged. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.